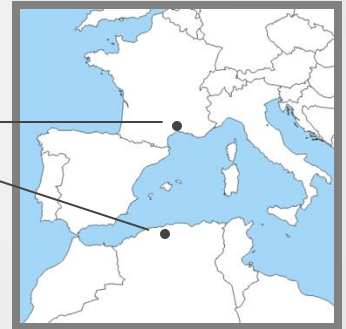


Leveraging a microservice architecture, access control and interoperability patterns to manage privacy-related user consents

Selena Lamari, Nadja Benblidia, Chouki Tibermacine, Christelle Urtado, Sylvain Vauttier

LIRMM, Univ. Montpellier, CNRS, Montpellier, France
LRDSI, Univ. Blida 1, Blida, Algeria



Leveraging a microservice architecture, access control and interoperability patterns to manage privacy-related user consents

Selena Lamari, Nadja Benblidia, Chouki Tibermacine, Christelle Urtado, Sylvain Vauttier

LRDSI, Univ. Blida 1, Blida, Algeria



Leveraging a microservice architecture, access control and interoperability patterns to manage privacy-related user consents

Selena Lamari, Nadjia Benblidia, Chouki Tibermacine, Christelle Urtado, Sylvain Vauttier

Université Bretagne Sud, UMR CNRS 6074, IRISA, Vannes, France



Leveraging a microservice architecture, access control and interoperability patterns to manage privacy-related user consents

Selena Lamari, Nadja Benblidia, Chouki Tibermacine, Christelle Urtado, Sylvain Vauttier

EuroMov Digital Health in Motion, Univ. Montpellier & IMT Mines Ales, Ales, France



EuroMov
Digital Health in Motion



IMT Mines Ales
Ecole Mines/télécom

OUTLINE

1. Context and motivation
2. Focus on consent management
3. Authentication / Authorization service
4. Consent management based on the ABAC pattern
5. Case study
6. Conclusion and future work





Context and motivation

Privacy is key in a world where human beings are being monitored a lot:

- IoT devices
- internet usage
- connected health
- AI

Regulations exist that should impact software development:

- CPRA (California Consumer Privacy Act) – California
 - **GDPR (General Data Protection Regulation) - EU**
 - LGPD (Lei Geral de Proteção de Dados) – Brasil
 - ...
- 



Context and motivation

Overarching objective:

Help architects /developers implement **privacy** concerns as prescribed by **GDPR** into their applications

Methodology:

- Read GDPR and formalize its principles as a metamodel
 - Qualitatively validate metamodel: review by experts
 - Define a DSL for annotating data and processings
 - Implement GDPR principles at runtime:
 - Lawfulness, fairness, and transparency
 - **Data subject rights**
 - Purpose limitation
 - Storage duration limitation
-





Focus: Consent management enforcement

Principles:

- Consent must be freely given, **specific**, **explicit**, and informed.
- Users must be able to **withdraw** their consent as easily as they gave it.
- Companies must respect users' consents.
- Companies must be able to **prove** that consent was given.

Research question:

How can access to personal data be conditioned by user consent?





Contributions

PRIAM MSA : PRIvacy Assesment Model MicroService Architecture

Authentication / Authorization service

- Secure authentication and authorization management: OAuth2 and OpenID Connect (OIDC)
- Single connection for all services: SSO (Single Sign-On)

Consent management and data protection

- Give / withdraw consent easily
 - ABAC for access control: access decisions are based on user consents at all times
 - Consent history: full traceability, proof of GDPR compliance
 - Microservices for centralized management: in an application-independent manner
-



Contributions

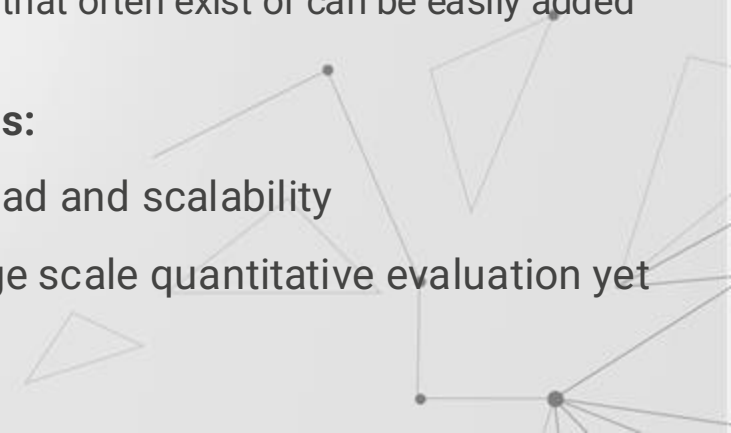
PRIAM MSA : PRIvacy Assesment Model MicroService Architecture

Originality:

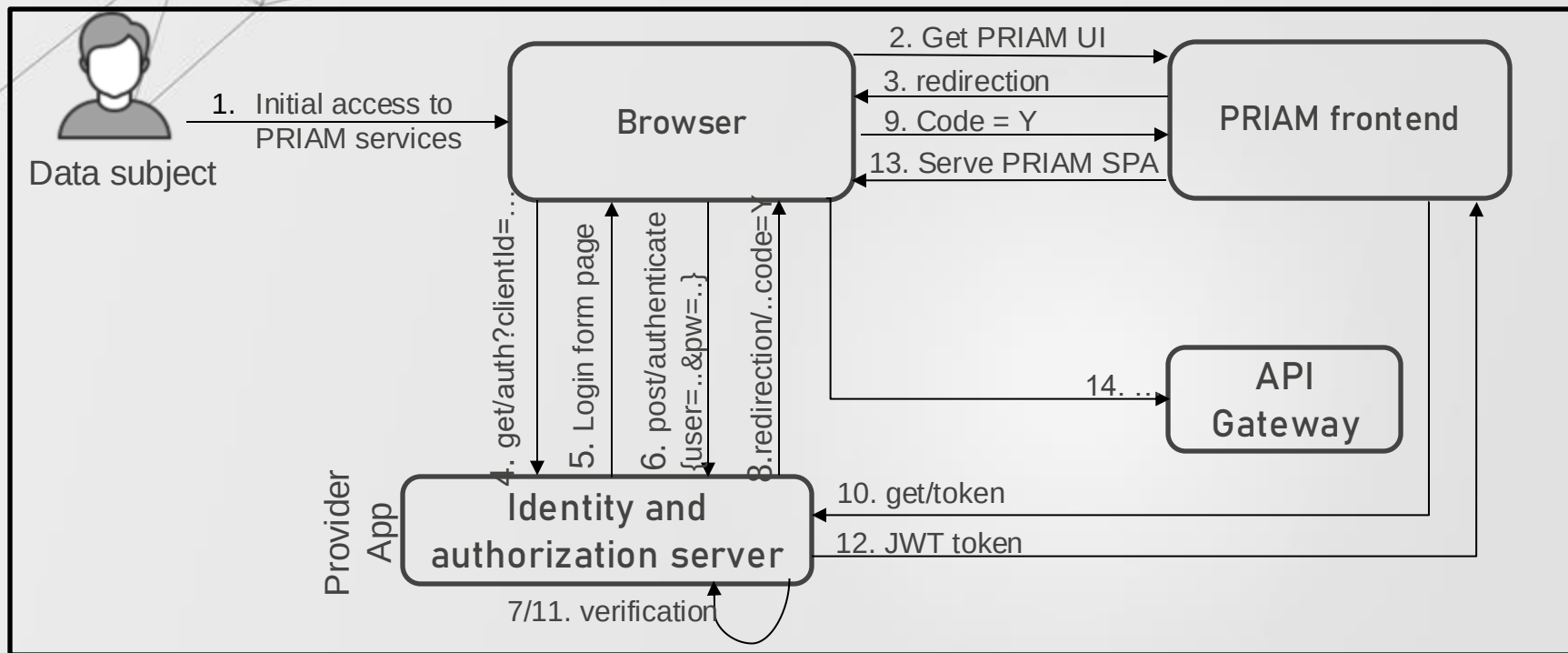
- Part of an overarching project that tools GDPR integration for architects / developers
- Little impact on the application
 - Requires only a PRIAM front-end and REST API endpoints that often exist or can be easily added
 - Do not alter / copy personal data

Limitations:

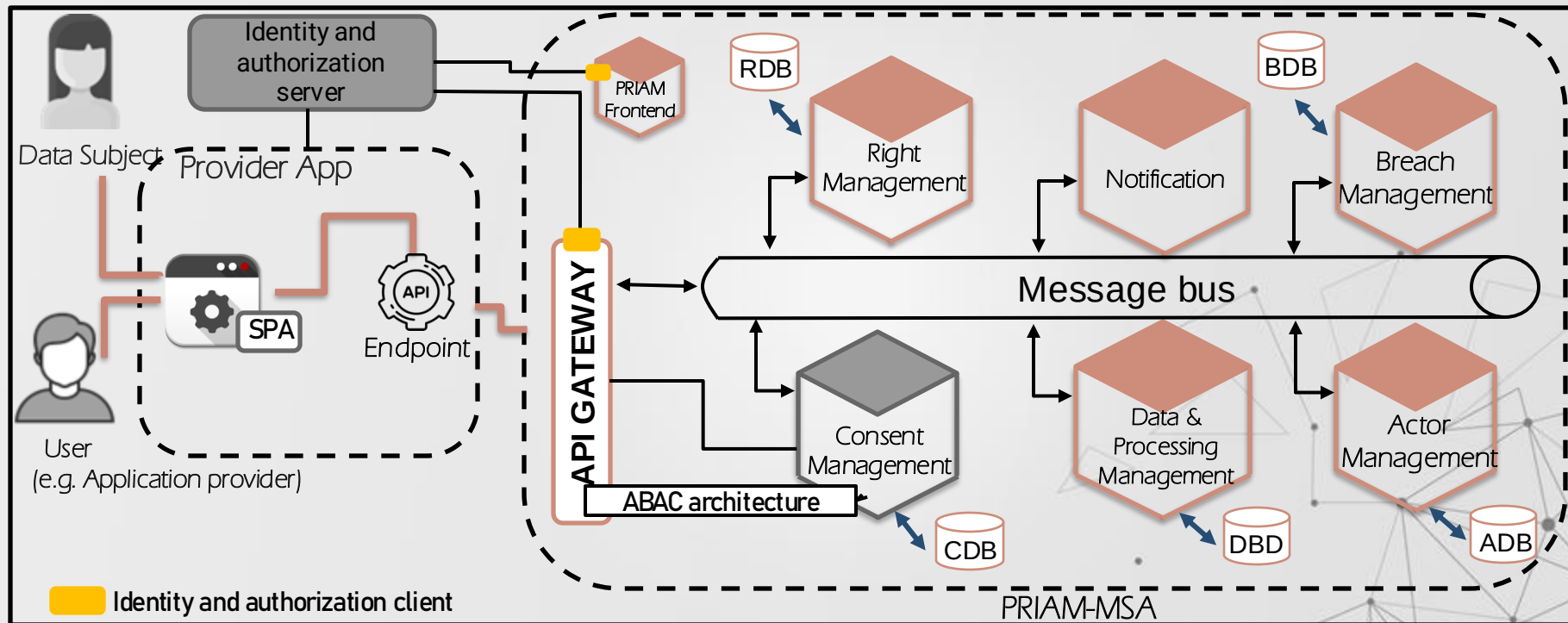
- Overhead and scalability
 - No large scale quantitative evaluation yet
-



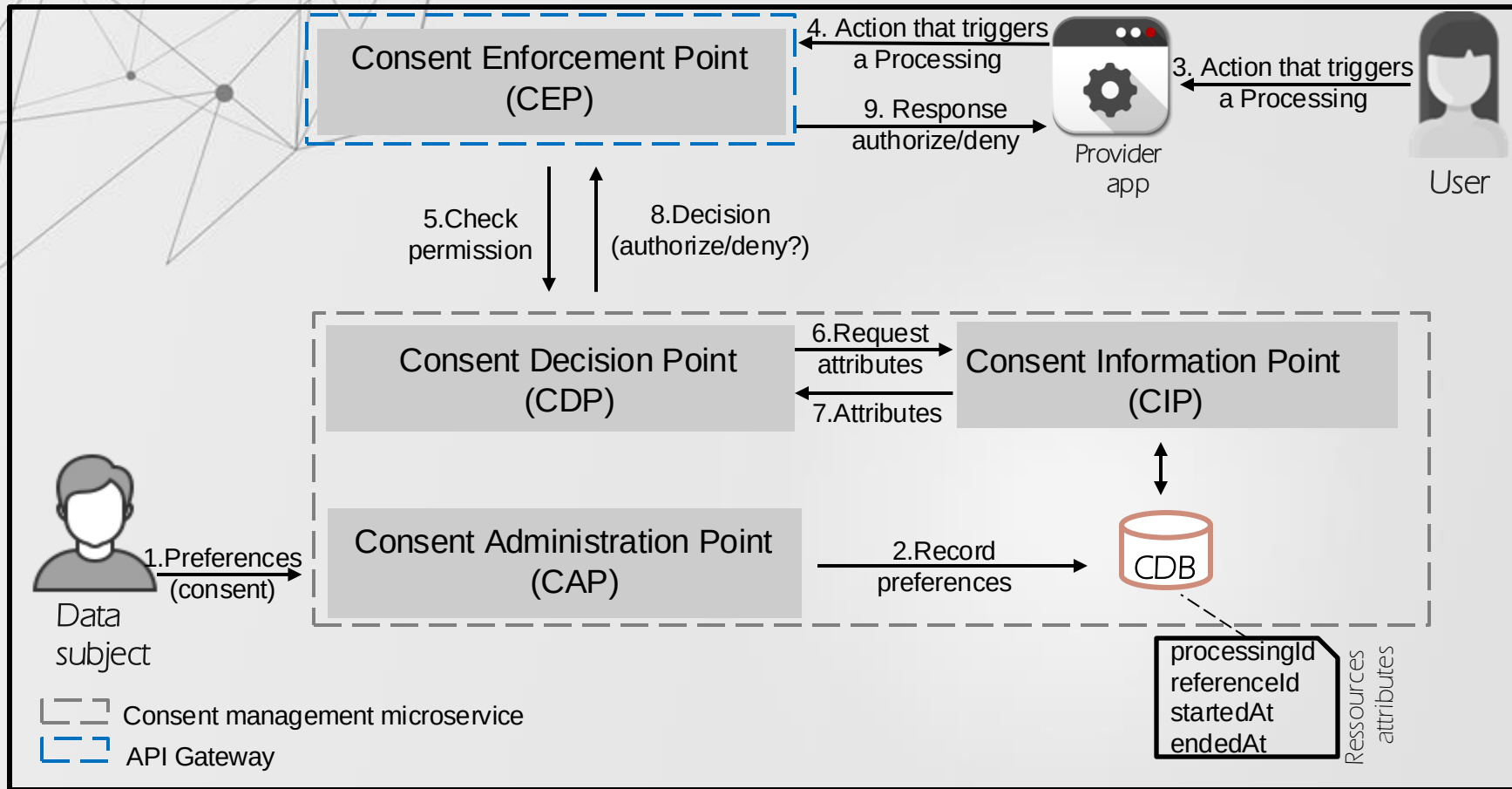
Authentication / Authorization service



Architecture of the Consent Management System



ABAC pattern for Consent-based access controller





Case study: Making the TeaStore application privacy-aware

Why TeaStore?

- Open-source reference application for micro-service architecture implementation
 - Database schema available
 - Uses data that can be considered private
 - Still has sense if some (optional) processings are de-activated when user consent is not given
-



Case study: Small development cost

part of the “recommended products” function

```
try {  
    List<Long> result = recommender.recommendProducts(userid, currentItems);  
}
```

part of the “recommended products” function code with consent management

```
String methodName = new Object() {}.getClass().getEnclosingMethod().getName();  
String className = new Object() {}.getClass().getEnclosingClass().getSimpleName();  
String processingId = className + "." + methodName;
```

```
// call the consent manager  
canUse = getConsent(userid, processingId);
```

```
// verify consent before executing product recommendation processing  
try {  
    if (canUse) {  
        result = recommender.recommendProducts(userid, currentItems);  
    } else {  
        result = new ArrayList<>();  
    }  
}
```

- Check consent
- Condition execution to consent

Case study: Example UI to give / withdraw consent

[PRIAM](#) [My Rights](#) [Requests](#) [Consent](#) Joseph <706> 

Optional processing

 recommender

Give/Withdraw Consent  

Informations for recommender

- Edited at 2024-05-22T22:28:30.000+00:00
- Purposes:
 - Recommend products tailored to the user's preferences and behaviors to provide them with a personalized shopping experience. (MAIN)
- Data:

	Create	Read	Update	Delete
po_ADDRESS1		X		
po_ADDRESS2		X		
po_ADDRESSNAME		X		
po_CREDITCARDCOMPANY		X		
po_CREDITCARDNUMBER		X		
po_CREDITCARDEXPIREDATE		X		
po_EMAIL		X		

Necessary processing

 place an order

Give/Withdraw Consent  

- Same toggle to give / withdraw consent
 - Time of last change (historized)
 - Purpose
 - Impacted data
-
- Toggle is grayed if processing cannot be removed



CONCLUSION AND FUTURE WORK

PRIAM MSA:

- Help applications enforce GDPR user consent @ runtime
- Low impact on the application / low development effort
- Secure (authentication, authorization) and still not too intrusive (SSO)
- Enforce consent management using microservice architecture and ABAC pattern

Perspectives:

- Mining code repositories for project snapshots before vs after GDPR integration
 - Evaluate our proposed solution quantitatively
 - Evaluate / measure GDPR compliance
- Assess time and space overhead / study scalability (replication?)

Leveraging a microservice architecture, access control and interoperability patterns to manage privacy-related user consents



Christelle Urtado
Christelle.Urtado@mines-ales.fr

Take-aways

- Help applications enforce **GDPR** user consent @ runtime
- **Low impact** on the application / low development effort
- **Secure** (authentication, authorization) and still not too intrusive (SSO)
- Enforce **consent management** using **microservice architecture** and the **ABAC** pattern